

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 16

Rework SCP Targets, Recover Root, Rename LogArchive, and Recreate SecurityAudit

AWS Organizations | SCPs | Root Recovery | Account Lifecycle

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	July 14, 2026
STATUS	Complete

Executive Summary

Reworked the **ProtectRootAndOrg** Service Control Policy target strategy by attaching it to Organizational Units instead of the organization root, leaving **Exceptions** unprotected for controlled emergency/root-account operations. Moved the original **SecurityAudit** account into Exceptions, recovered the account root user, renamed the account to **LogArchive**, changed its root email address, moved LogArchive back into the **Security** OU, and recreated a new **SecurityAudit** account.

Business Problem

The original organization-wide SCP protected all descendant accounts from root-account API activity, but that also created a problem: there was no OU where an account could be temporarily moved when root access was legitimately required for account recovery or account-level settings. This project establishes a controlled exception process while still restoring strong protection after the sensitive work is complete.

Objectives

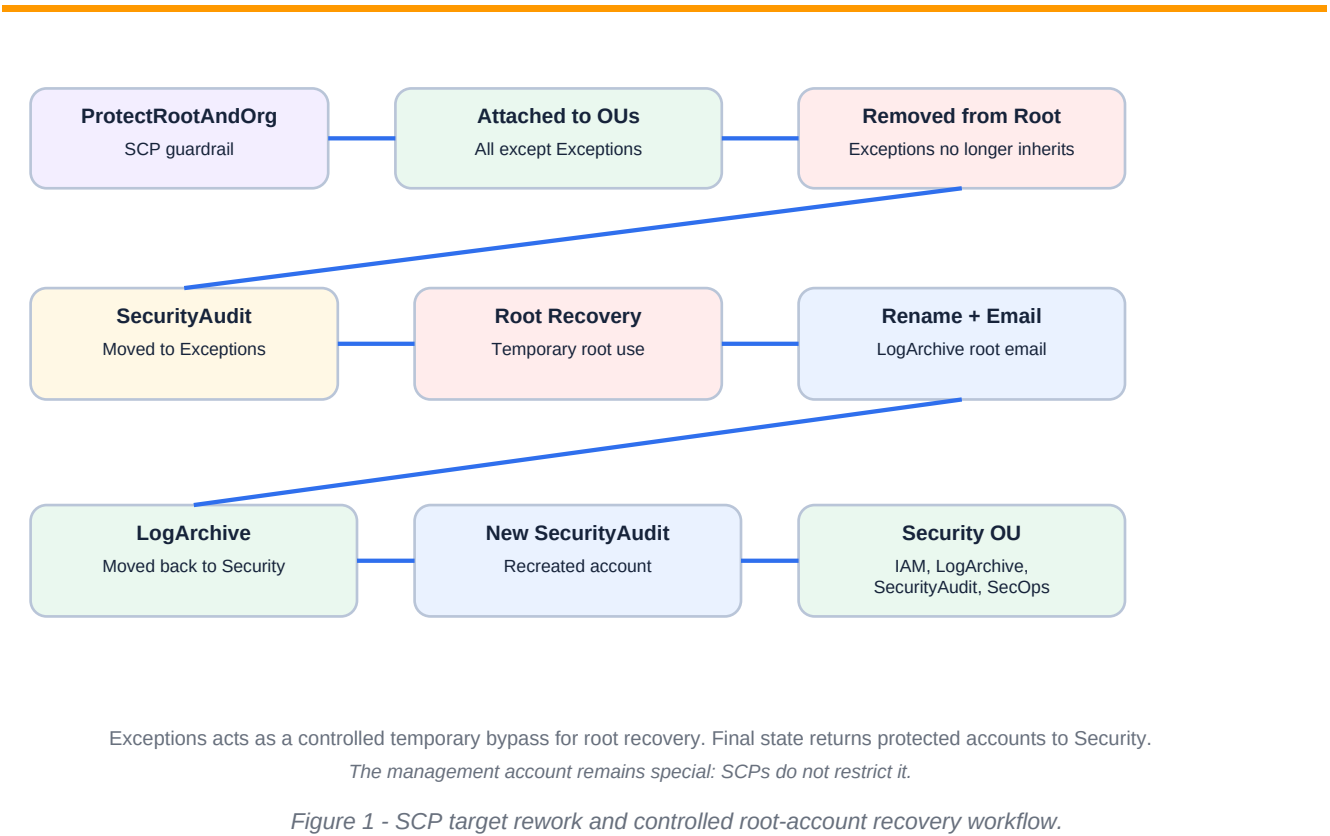
- Attach ProtectRootAndOrg to all intended OUs except Exceptions.
- Remove the organization Root target from ProtectRootAndOrg.
- Use the Exceptions OU as a temporary bypass for root-account recovery.
- Move the original SecurityAudit account into Exceptions.
- Recover the root user for the original SecurityAudit account.
- Rename the original SecurityAudit account to LogArchive and update its root email address.
- Move LogArchive back into the Security OU so ProtectRootAndOrg applies again.
- Recreate a new SecurityAudit account and place it with the other Security OU accounts.

Environment

Cloud Provider	Amazon Web Services (AWS)
Primary Service	AWS Organizations
Primary Policy	ProtectRootAndOrg
Policy Type	Service Control Policy
SCP Strategy	Attached to OUs instead of organization Root
Intentional Exception	Exceptions OU does not receive ProtectRootAndOrg
Temporary Account Movement	Original SecurityAudit moved to Exceptions for root recovery

Renamed Account	SecurityAudit renamed to LogArchive
Recreated Account	New SecurityAudit account created
Final Security OU Accounts	IAM, LogArchive, SecurityAudit, and SecurityOperations
Evidence Limitation	Target-list screenshot confirms visible OU targets and no Root target; full Workloads target inclusion is documented from user report if not visible in the captured viewport.

Architecture



Implementation Summary

1. Opened the ProtectRootAndOrg SCP target configuration.
2. Attached ProtectRootAndOrg to OUs throughout the organization while intentionally excluding Exceptions.
3. Removed the organization Root target from ProtectRootAndOrg so Exceptions would not inherit the root-deny control.
4. Moved the original SecurityAudit account into the Exceptions OU.
5. Recovered the root account for the original SecurityAudit account using the account email workflow.
6. Changed the original SecurityAudit account name to LogArchive.

- 7. Changed the root email address to a LogArchive-specific address.
- 8. Moved LogArchive back into the Security OU so it is again protected by ProtectRootAndOrg.
- 9. Created a new SecurityAudit account.
- 10. Validated the final Security OU account lineup: IAM, LogArchive, SecurityAudit, and SecurityOperations.

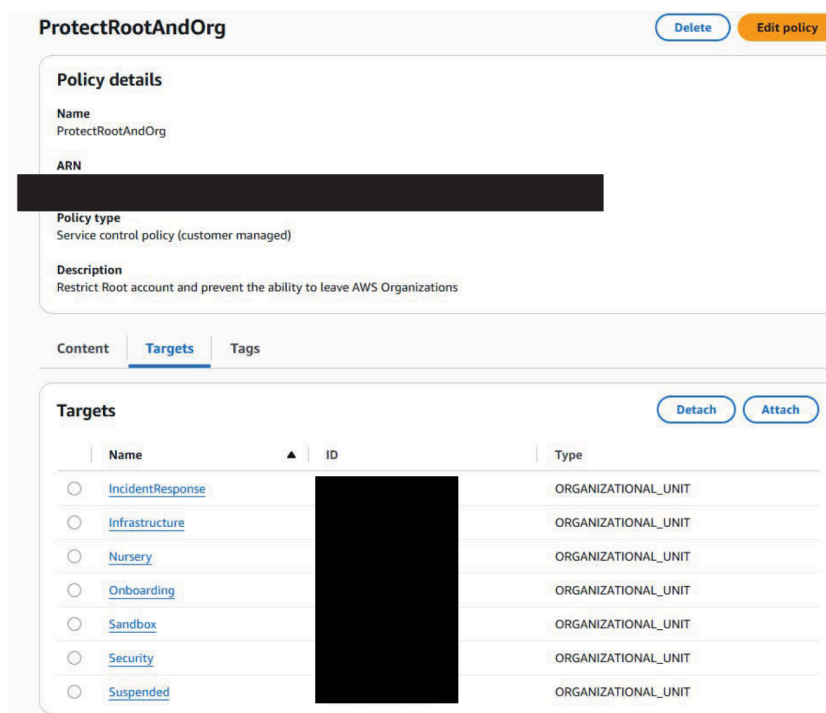
CONTROL
INTENT

The purpose of Exceptions is not to weaken the environment permanently. It gives a controlled location where sensitive account recovery can happen, after which the account is moved back under normal SCP protection.

Control Logic

ProtectRootAndOrg	Attached to OUs, not Root	Enables an Exceptions OU without root-deny inheritance.
Exceptions OU	No ProtectRootAndOrg target	Temporary recovery path for root-only operations.
Root target	Removed	Prevents Root-level attachment from overriding the Exceptions design.
Original SecurityAudit	Renamed to LogArchive	Aligns account purpose with centralized log storage.
LogArchive	Returned to Security OU	Restores SCP protection after recovery and rename.
New SecurityAudit	Created under Security OU	Restores a separate account for audit and assessment functions.

Evidence

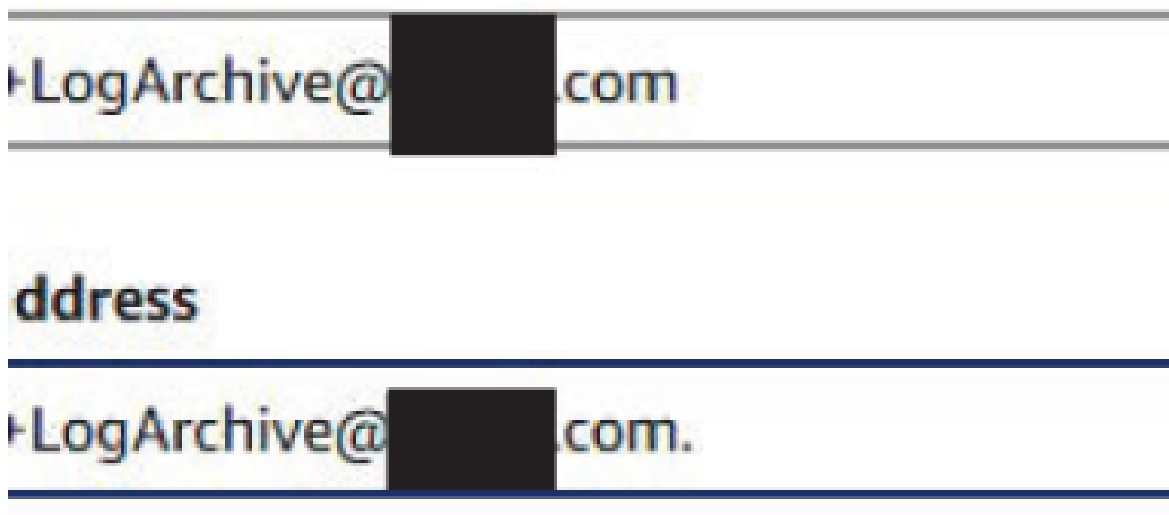
Figure 2 - ProtectRootAndOrg Attached to OU Targets Instead of Root

The redacted **ProtectRootAndOrg** target evidence shows visible OU targets including **IncidentResponse**, **Infrastructure**, **Nursery**, **Onboarding**, **Sandbox**, **Security**, and **Suspended**. The **Root** target is no longer listed, and **Exceptions** is not shown as a target. Sensitive policy identifiers were redacted before publication.

Figure 3 - SecurityAudit Temporarily Moved to Exceptions

The redacted organization hierarchy evidence shows **SecurityAudit** under the **Exceptions** OU. This places the account outside the **ProtectRootAndOrg** SCP scope so root-account recovery and account-level changes can be performed.

Figure 4 - LogArchive Root Email Address Updated



The redacted account settings evidence shows a LogArchive-specific email address value in the account email workflow. Sensitive email portions were redacted before publication.

Figure 5 - Final Security OU Account Structure



The redacted AWS Organizations hierarchy evidence shows the Security OU with IAM, LogArchive, SecurityAudit, and SecurityOperations accounts. LogArchive retains the earlier account creation date, while the recreated SecurityAudit account shows a later creation date.

Security Analysis

Moving ProtectRootAndOrg from the organization Root target to individual OU targets makes Exceptions a deliberate bypass location rather than an accidental gap.

Moving an account between OUs immediately changes the SCPs that apply to it. This is useful for controlled recovery workflows but also requires strong change control and logging.

Root account recovery is intentionally high-risk and should be rare. The workflow should use a strong random temporary password, avoid saving it, complete the required change, and then restore SCP protection.

Renaming the original SecurityAudit account to LogArchive corrects the account purpose: it now represents centralized log storage rather than audit-tool operation.

Recreating SecurityAudit restores separation between LogArchive and audit/assessment tooling, which is cleaner than combining storage and audit activity in one account.

Lessons Learned

SCP targeting strategy matters. Root-level attachment is broad, but OU-level attachment gives more precise governance control.

Exceptions should be designed as a temporary control path, not a permanent home for accounts.

Root-user sign-in itself is not fully blocked by SCPs because sign-in is not the same as an AWS API action. The goal is to block API activity and minimize root exposure.

AWS Organizations account names and root email addresses are operational details with security impact. They should follow a controlled naming and ownership model.

Production Improvements

- Create a separate DenyLeaveOrganization SCP that still applies to Exceptions while allowing controlled root-account recovery.
- Require approval, ticketing, and CloudTrail review before and after moving an account into Exceptions.
- Add alarms for account movement, SCP detach/attach activity, root password reset requests, and root sign-in.
- Document root recovery as a break-glass runbook with exact pre-checks, actions, and rollback steps.
- Use dedicated distribution lists or monitored aliases for root account email addresses.
- Consider service-control guardrails that limit what can be done in Exceptions even during recovery windows.

Skills Demonstrated

Service Control Policies	Root-account recovery	AWS Organizations
OU targeting	Exception workflow design	Account lifecycle management
Account rename/email update	Security account separation	Break-glass process

Resume Bullet

RESUME

Reworked AWS Organizations SCP targeting by attaching ProtectRootAndOrg to selected OUs instead of the organization root, used an Exceptions OU for controlled root-account recovery, renamed SecurityAudit to LogArchive, and recreated a dedicated SecurityAudit account to preserve separation of duties.

STAR Interview Story

Situation: The organization-level root-protection SCP was effective but too broad because it left no controlled path for root-only account recovery tasks.

Task: Rework the SCP target model and safely rename the original SecurityAudit account to LogArchive while restoring audit account separation afterward.

Action: I attached ProtectRootAndOrg to OUs except Exceptions, removed the Root target, moved SecurityAudit into Exceptions, recovered root, changed the account name and email to LogArchive, moved LogArchive back into Security, and recreated SecurityAudit.

Result: The environment now has a controlled exception path for root recovery, a properly named LogArchive account, a recreated SecurityAudit account, and restored SCP protection for security accounts.

Version History

v1.0.0	July 14, 2026	Initial documented implementation. Reworked ProtectRootAndOrg OU targets, removed Root target, used Exceptions for controlled root recovery, renamed SecurityAudit to LogArchive, changed the root email, moved LogArchive back to Security, recreated SecurityAudit, and embedded all provided evidence using portfolio documentation standard v1.0.1.

References

- Cloud Security Lab a Week (S.L.A.W.) - OUs, SCPs, and a Root User Account Recovery.
- User-provided ProtectRootAndOrg target list evidence.
- User-provided SecurityAudit in Exceptions evidence.
- User-provided LogArchive email change evidence.
- User-provided final Security OU account hierarchy evidence.
- Project 15 - AWS Organizations Enterprise OU Structure.